Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

Team leader : P.Nandhini

Team Members:

S.Thasneem

K.Y.Aishwarya

R.D.Swathi priya

S.Thrisha

Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

Project details

Title: Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

This project describes the strategy and implementation plan for integrating the Zscaler security platform with the organization's primary Identity Providers (IdPs), including Microsoft Entra ID (Azure AD), Okta, and the on-premises Active Directory environment. The main goal is to establish a unified, secure, and automated system for user authentication and authorization across all Zscaler services.

Instead of managing users separately within individual systems, this approach relies on centralized identity platforms to strengthen security and simplify access management. By adopting this model, the organization moves closer to a Zero Trust architecture where user access is continuously verified based on identity and contextual factors. It also enables consistent enforcement of security measures such as Multi-Factor Authentication (MFA) while improving the user experience through Single Sign-On (SSO).

Overall, this integration will act as a vital connection between the organization's identity infrastructure and its security control layer, ensuring that authorized users receive the appropriate level of secure access to internet resources and applications, regardless of where they are working from.

Abstract:

This project explains the integration of the Zscaler Internet security platform with major Identity Providers (IdPs) such as Microsoft Entra ID (Azure AD), Okta, and the organization's on-premises Active Directory environment. The main aim of this integration is to create a unified identity management framework that supports seamless Single Sign-On (SSO) and centralized authorization across all Zscaler services. By relying on trusted enterprise directories for authentication, the organization can remove the need for multiple login credentials while establishing a strong foundation for a modern Zero Trust security architecture.

The integration utilizes widely adopted identity protocols such as SAML, OIDC, and SCIM to delegate user authentication to corporate identity platforms. Through this approach, security policies including Multi-Factor Authentication (MFA) can be applied consistently for all users accessing Zscaler services. This not only improves the user experience by minimizing the need to remember multiple passwords but also strengthens the organization's security framework by ensuring that every access attempt is validated by the identity provider before reaching Zscaler's security control points.

In addition, automated user provisioning through SCIM simplifies user lifecycle management by automatically creating, updating, and removing user accounts when changes occur in the identity directory. This reduces manual administrative effort while improving overall security management. As a result, the integration supports an identity-driven security model that follows Zero Trust principles, ensuring that only verified and authorized users are allowed secure access to internet and cloud-based applications from any location. Ultimately, this implementation connects identity governance with network security, creating a flexible and efficient

Use Case Scenarios:

Use Case Scenario 1: Remote Faculty Access to Research Data

A research professor attending an academic conference outside the campus requires secure access to confidential research files stored on an internal university server. Rather than connecting to the entire campus network through a traditional VPN, Zscaler Private Access (ZPA) allows the professor to connect only to the required research server. Authentication is performed through the university's identity provider, and access permissions are granted according to the professor's role within the institution.

Output:

- **User identity confirmed:** Member of the *Research Faculty Group*
- **Context-based policy applied:** Access permitted only from external (non-campus) network locations
- **Restricted connection:** Limited to the designated Research File Server (*R&D Server*)
- **Security control:** Multi-Factor Authentication (MFA) enforced due to remote access
- **Restricted movement:** The user is prevented from accessing unrelated internal systems such as HR or student information platforms

Use Case Scenario 2: Student Access to Library Resources

A graduate student studying off-campus needs to access subscription-based academic journals and digital library databases that are hosted within the university network. Instead of requiring the student to establish a complete VPN connection, ZPA enables secure and direct access to the library application portal. Authentication is completed through the institution's identity provider, ensuring that only currently enrolled students can view and use licensed resources.

Output:

- **User identity validated:** Member of the *Enrolled Student Group*
- **Defined access scope:** Limited to the Library Portal and journal database services
- **Policy enforcement:** Access restricted to authorized users, preventing misuse or credential sharing
- **Improved user experience:** Smooth Single Sign-On (SSO) without the need for a VPN client
- **No full network exposure:** Students cannot access administrative platforms or other internal servers

Use Case Scenario 3: HR Administrator Access to Payroll System

An HR administrator needs to log in to the payroll application to complete monthly salary processing. Because payroll data is highly sensitive, access must follow strict security policies. The administrator authenticates using the organization's identity provider, and ZPA applies additional controls such as restricted access hours and step-up authentication to ensure compliance with security requirements.

Output:

- **User identity verified:** Member of the *HR Admin Group*
- **Access limitation:** Restricted to the Payroll Management System only
- **Time-based policy:** Access permitted only during approved working hours
- **Enhanced authentication:** Multi-Factor Authentication (MFA) required for payroll system access
- **Security protection:** No access to other internal systems outside the administrator's role

Use Case Scenario 4: IT Helpdesk Remote Troubleshooting

An IT support technician working from home needs to diagnose and resolve an issue on a specific internal server. Instead of granting permanent administrative privileges or broad network access, Zscaler Private Access (ZPA) provides Just-in-Time (JIT) access to the required server. The technician first authenticates through the organization's identity provider, after which temporary administrative permissions are granted only for the duration of the maintenance task.

Output:

- **User identity confirmed:** Member of the *IT Helpdesk Group*
- **Just-in-Time access provided:** Administrative privileges granted only during the active troubleshooting session
- **Restricted connectivity:** Access limited strictly to the designated server (*Server-X*)
- **Privilege control enforced:** No visibility or access to other infrastructure components such as databases or domain controllers
- **Session monitoring enabled:** All activities are recorded in real time for auditing and security review

Use Case Scenario 5: Contractor Access to Project Management Tool

An external project manager hired for a specific initiative requires access to the organization's project management platform, such as Jira or SharePoint. Since the user is not a permanent employee, access must be carefully controlled and automatically removed once the contract period ends. The contractor authenticates through the organization's identity provider, and ZPA grants limited application access based on group membership that is synchronized from Azure AD.

Output:

- **User identity verified:** Member of the *External_Contractor_Group*
- **Time-limited access applied:** User account and permissions automatically revoked after the contract expiration date
- **Restricted application access:** Limited only to the designated Project Management Application
- **Network segmentation enforced:** Contractor cannot view or connect to internal resources such as financial systems or student information databases

Stage-1

Title Of the Project: -

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview: -

The integration of Zscaler with enterprise Identity Providers (IdPs) introduces a major transformation in the way organizations manage secure access to applications and digital resources. In traditional security models, organizations depended heavily on VPN connections and perimeter-based protection methods. These approaches often resulted in users receiving broader access than required, increasing the risk of unauthorized lateral movement within the network. In contrast, this project utilizes the capabilities of the Zscaler Zero Trust Exchange platform, which focuses on verifying user identity at the application layer instead of relying solely on the network layer. by integrating with widely used identity providers such as Microsoft Entra ID, Okta, and on-premises Active Directory, the system establishes a unified and consistent identity framework across the organization. This approach guarantees that users are authenticated in a uniform manner regardless of the device they use or their physical location. The solution also removes the necessity for maintaining duplicate user directories or performing manual account management within Zscaler.

Users benefit from a simplified authentication experience where logging in once enables them to reach all resources they are authorized to use. Meanwhile, security administrators maintain centralized oversight and management of authentication policies as well as the entire user lifecycle. The system is designed to work with modern authentication standards such as **SAML**, **OIDC**, and **SCIM**, ensuring secure and standardized identity communication between platforms. In the end, this structure strengthens a **Zero Trust** security framework in which user identity serves as the main factor for regulating and enforcing access to organizational resources. This integration uses the **SAML 2.0** protocol to create a federated trust relationship between Zscaler and Entra ID, enabling seamless **Single Sign-On (SSO)** for users. When individuals attempt to access Zscaler Internet Access or Zscaler Private Access portals, they are redirected to Entra ID to complete the authentication process. Through this method, organizations can apply Conditional Access policies defined in Entra ID during authentication.

These policies may require device compliance checks, location-based restrictions, or risk-based access conditions before granting entry to Zscaler services The integration also goes beyond simple authentication by supporting automated user provisioning through the **SCIM** protocol. User profiles and group memberships are continuously synchronized from Entra ID to Zscaler, ensuring that identity information remains accurate and up to date. This automation removes the need for manual account creation and reduces the chances of configuration errors. It also guarantees that access is revoked immediately when employees leave the organization. Additionally, Entra ID provides detailed reporting and auditing features that allow administrators to monitor authentication activities and detect potential security issues. Together, these capabilities create a strong and unified security framework that uses Microsoft's identity platform to safeguard resources managed through Zscaler.

Similarly, integration with Okta offers a flexible and vendor-neutral identity management solution for Zscaler environments. As a widely adopted independent Identity Provider, Okta enables organizations to connect Zscaler with a broad range of applications and directory services. This integration relies on the **OpenID Connect (OIDC)** protocol to provide modern and API-driven authentication for Zscaler platforms. The use of OIDC supports enhanced user context and enables secure, scalable authentication across multiple systems and applications.

List of Vulnerability Table:

Practice Website:

S.no	Vulnerability name	CWE - No
1	Weak Encoding for Password	CWE-261 Weak Encoding for Password
2	Man-in-the-Middle Attack	CWE-296 Improper Following of a Certificate's Chain of Trust
3	Cleartext Transmission of Sensitive Information	CWE-319 Cleartext Transmission of Sensitive Information
4	Key Management Errors (Prohibited)	CWE-320 Key Management Errors (Prohibited)
5	Absolute Path Traversal	CWE-36 Absolute Path Traversal

6	Small Space of Random Values	CWE-334 Small Space of Random Values
7	Use of Hard-coded Cryptographic Key	CWE-321 Use of Hard-coded Cryptographic Key
8	Key Exchange without Entity Authentication	CWE-322 Key Exchange without Entity Authentication
9	Reusing a Nonce, Key Pair in Encryption	CWE-323 Reusing a Nonce, Key Pair in Encryption
10	Use of a Key Past its Expiration Date	CWE-324 Use of a Key Past its Expiration Date

Main Website

S.no	Vulnerability Name	CWE – No
1	SL Medium Strength Cipher Suites Supported (SWEET32)	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor
2	Cookie SERVERID created without secure flag	CWE-79: Improper Neutralisation of Input During Web Page Generation
3	X-Content-Type Options Header Missing	CWE-918: Server-Side Request Forgery (SSRF)
4	Denial of Service	CWE -400: Uncontrolled Resource Consumption
5	OS Identification	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

REPORT: -

Practice Website: http://www.itsecgames.com/

1)Vulnerability Name:

Weak Encoding for Password

CWE- 284:

Improper Access Control

OWASP Category:

A04:2025 Cryptographic Failures

Description:

refers to a security vulnerability where a system stores or transmits user passwords using weak encoding methods instead of strong cryptographic protection

Business Impact:

If attackers decode the stored passwords, they can log in to user accounts without authorization. This can allow them to access personal data, perform transactions, or misuse the system. Large numbers of compromised accounts can damage customer trust.

Steps to Reproduce:

https://cwe.mitre.org/data/definitions/261.html

1. Use Strong Password Hashing Algorithms

Passwords should never be stored using encoding methods. Instead, they must be protected using secure hashing algorithms specifically designed for password storage such as bcrypt Argon2

2. Implement Salting

Each password should be combined with a unique random salt before hashing. Salting ensures that even if two users have the same password, their stored hashes will be different. This protects against rainbow table attacks.

3. Enforce Strong Password Policies

Applications should require users to create strong passwords by enforcing rules such as:

- Minimum length (e.g., 8–12 characters)
- Combination of uppercase, lowercase, numbers, and symbols
- Prevention of common or previously used passwords

2)Vulnerability Name:

Man-in-the-Middle Attack

CWE-395:

Improper Certificate Validation

OWASP Category:

A07:2021 – Identification and Authentication Failures

Description

A Man-in-the-Middle (MitM) attack is a type of cyberattack in which an attacker secretly intercepts and possibly alters the communication between two parties who believe they are communicating directly with each other. The attacker positions themselves between the client and the server, allowing them to monitor, capture, or manipulate the transmitted data without the knowledge of either party.

Business Impact:

A Man-in-the-Middle (MitM) attack can seriously affect an organization because attackers secretly intercept and manipulate communication between users and systems. This can lead to multiple business risk.

Recommendation:

1. Use Secure Communication Protocols

Always use encrypted communication protocols such as HTTPS, SSL, or TLS for data transmission. Encryption protects sensitive information from being intercepted or modified by attackers during transmission.

2. Proper Certificate Validation

Applications should strictly validate digital certificates and verify the certificate chain of trust. This ensures that the server is authentic and prevents attackers from using fake certificates.

3. Implement Certificate Pinning

Certificate pinning allows an application to accept only specific trusted certificates. This reduces the risk of accepting fraudulent certificates issued by compromised certificate authorities.

4. Enable Multi-Factor Authentication (MFA)

Implementing MFA adds an additional layer of security during user authentication. Even if attackers intercept credentials, they will not be able to access the system without the second authentication factor**.**

Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	web.mmebvba.com Fingerprint SHA256: 9e7275cb84903692044a0e1f9b64d1426869813b55b28157913b7e49e778f87e Pin SHA256: moilG7Pck7rm7Q7pJpb+augA9cuCc0eOAxVrTFBhY0M=
Common names	web.mmebvba.com
Alternative names	- INVALID
Serial Number	00ba5e79e0c2f743cb
Valid from	Mon, 25 May 2015 09:07:54 UTC
Valid until	Thu, 22 May 2025 09:07:54 UTC (expires in 1 year and 7 months)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	web.mmebvba.com Self-signed
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	No
OCSP Must Staple	No
Revocation information	None
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows

Additional Certificates (if supplied)

Certificates provided	1 (712 bytes)
Chain issues	None

Certification Paths

Mozilla Apple Android Java Windows

Path #1: Not trusted (path does not chain to a trusted anchor)

1	Sent by server Not in trust store	web.mmebvba.com Self-signed Fingerprint SHA256: 9e7275cb84903692044a0e1f9b64d1426869813b55b28157913b7e49e778f87e Pin SHA256: moilG7Pck7rm7Q7pJpb+augA9cuCc0eOAxVrTFBhY0M= RSA 2048 bits (e 65537) / SHA256withRSA

3)Vulnerability Name:

Cleartext Transmission of Sensitive Information

CWE-319:

Cleartext Transmission of Sensitive Information

OWASP Category:

A04:2021-Insecure Design

Description:

Cleartext Transmission of Sensitive Information happens when sensitive data is sent across a network without encryption. This means the information is transmitted in plain, readable text, allowing anyone who intercepts the network traffic to easily view or steal the data

Business Impact:

When sensitive data such as login credentials, personal information, or financial details are transmitted without encryption, attackers can easily intercept the data. This can result in large-scale data breaches and exposure of confidential information.

Steps to Reproduce:

- **Open the target web application**
  Access the application using a browser where login or sensitive data transmission occurs.
- **Start a network monitoring tool**
  Use a packet-capture or interception tool such as **Wireshark** or **Burp Suite** to monitor the network traffic.
- **Perform a sensitive action**
  Enter sensitive information in the application, such as username, password, personal details, or payment information.
- **Capture the network request**
  Observe the HTTP request/response in the monitoring tool while the data is being transmitted.
- **Inspect the captured traffic**
  Check the request payload or headers. If the application is using **HTTP** instead of **HTTPS**, the sensitive information will appear in readable (plain text) format.
- **Verify the vulnerability**
  Confirm that sensitive data such as passwords, session IDs, or personal information can be clearly viewed in the captured traffic, proving that the data is transmitted without encryption.

Recommendation:

- **Use Secure Communication Protocols**

Always transmit sensitive information using **HTTPS** instead of **HTTP**. HTTPS uses **Transport Layer Security** to encrypt data during transmission, preventing attackers from reading the information.

- **Enforce TLS Encryption**

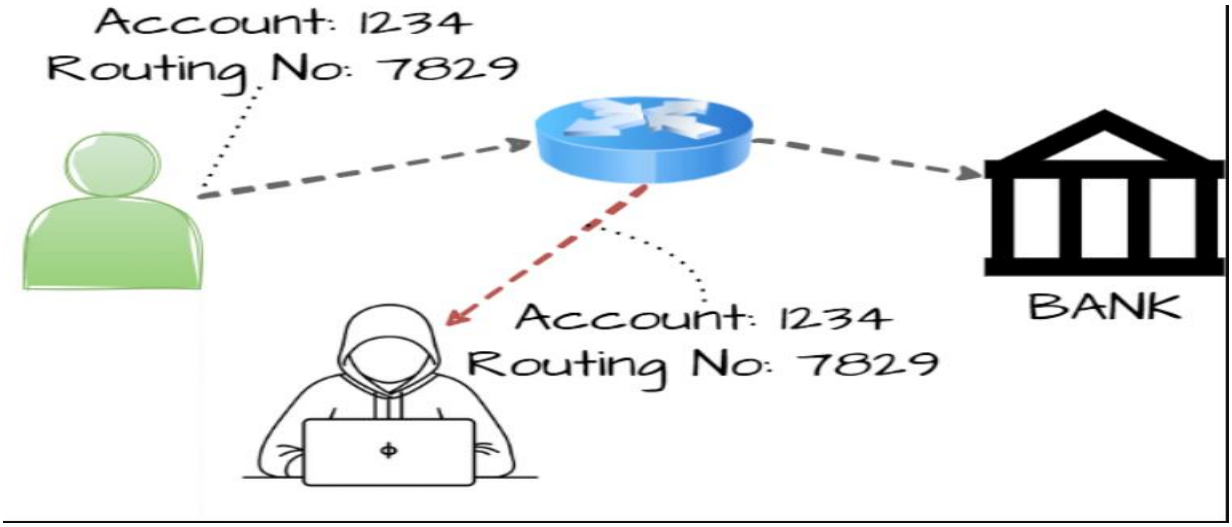
Configure the server to enforce TLS for all connections. Disable insecure protocols such as **Telnet** and **FTP**, and replace them with secure alternatives like **SFTP** or **SSH**.

- **Implement HSTS**

Enable **HTTP Strict Transport Security** so that browsers automatically use HTTPS and prevent accidental connections over HTTP.

- **Encrypt Sensitive Data Before Transmission**

In addition to transport encryption, encrypt critical data such as authentication tokens or confidential information using strong cryptographic algorithms before sending it across the network.



4)Vulnerability Name:

key management error (Prohibited)

CWE -320:

key management error (Prohibited)

OWASP Category:
A10:2021 – Server-Side Request Forgery (SSRF)

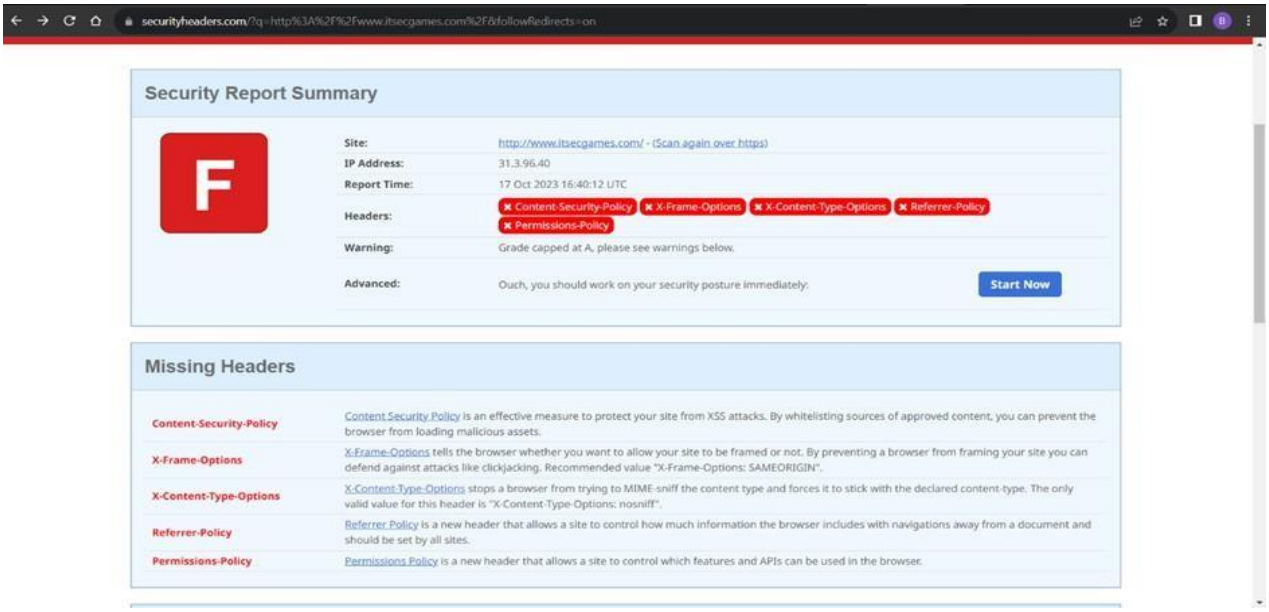
Description:
Key Management Errors occur when cryptographic keys are improperly generated, stored, distributed, or protected within an application or system. These errors often happen when developers store keys in plain text, hard-code them directly into the source code, reuse the same key for long periods, or fail to securely rotate and manage them.

Business Impact:
If encryption keys are poorly managed, attackers can obtain the keys and decrypt protected information such as customer records, login credentials, and financial data. This defeats the entire purpose of encryption**.**

Vulnerability Path: **https://cwe.mitre.org/data/definitions/320.html**

Recommendation:

- **Use Secure Key Management Systems**
  Store and manage cryptographic keys using a dedicated key management solution such as a Hardware Security Module (HSM) or a trusted cloud key management service like AWS Key Management Service, Azure Key Vault, or Google Cloud Key Management Service. These systems protect keys from unauthorized access and provide controlled key usage.
- **Avoid Hardcoding Keys in Source Code**
  Never store encryption keys, API keys, or private keys directly in the application source code or configuration files. Instead, store them securely in environment variables or secret management tools.
- **Implement Strong Access Control**
  Restrict access to cryptographic keys using role-based access control (RBAC). Only authorized users or systems should be able to access or modify the keys.
- **Use Key Rotation Policies**
  Regularly rotate encryption keys to minimize the risk of compromise. Automated key rotation policies should be implemented to ensure keys are replaced periodically



5)Vulnerability Name:

Absolute Path Traversal

CWE-937,1035:

CWE-36 Absolute Path Traversal

Description:

Absolute Path Traversal is a security vulnerability that occurs when an application uses user-supplied input to access files on the server using absolute file paths without proper validation or restriction. This allows an attacker to manipulate the file path and directly reference sensitive files located outside the intended directory.

Business Impact:

Attackers may access confidential files such as system configuration files, database credentials, or application source code. This can expose sensitive business information and internal system details.

Vulnerability Path: **http://example.com/download?file=/etc/passwd**

Recommendation:

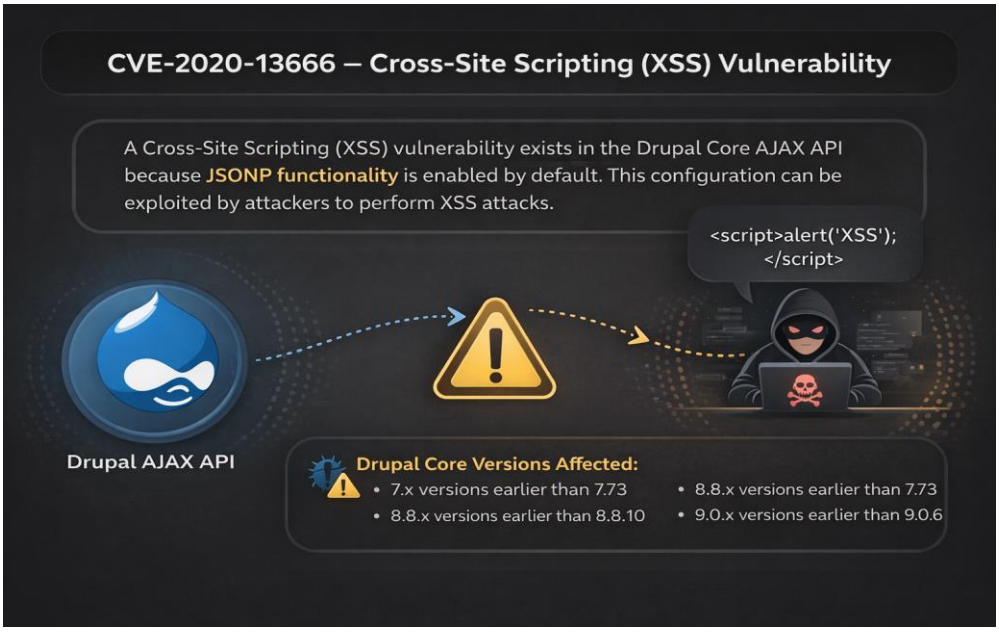
- **Validate and Sanitize User Input**

Do not allow user input to directly control file paths. Validate all inputs and reject any values that contain suspicious characters such as `/`, `\`, or `..` that may be used to access unauthorized directories.

• **Use Whitelisting for File Access**
Allow access only to specific files or directories that are required by the application. Implement a whitelist approach instead of accepting arbitrary file paths from users.

• **Restrict File System Permissions**
Configure the server with proper file permissions so that the application can only access necessary directories. Sensitive system files should not be readable by the application process.

• **Use Secure File Handling Functions**
Use safe APIs and built-in security functions that prevent directory traversal attacks and enforce path restrictions within the application.



6) Vulnerability Name:

Small Space of Random values

CWE-20:

CWE-334 Small Space of Random Values

OWASP Category:

A03:2021 – Injection

Description:

The number of possible random values is smaller than needed by the product, making it more susceptible to brute force attacks**.**

Business Impact:

An attacker could easily guess the values used. This could lead to unauthorized access to a system if the seed is used for authentication and authorization.

Vulnerability Path: **https://csrc.nist.gov/files/pubs/fips/140-2/upd2/final/docs/fips1402**

Steps to Reproduce:

CVE-2022-25271 Severity: 4.3

The **Form** API in Drupal core contains a **security flaw** where some contributed or custom module forms may not properly validate user input.

Because of this weakness, an attacker might be able to **submit unauthorized values** or modify existing data.

Although the number of affected forms is limited, in certain situations this vulnerability could allow changes to important or sensitive information.

Recommendation:

- **Use Strong Random Number Generators**
  Avoid predictable or weak random number generators. Use cryptographically secure random number generators such as those provided by OpenSSL or Java Secure Random to generate unpredictable values.
- **Increase Random Value Length**
  Ensure that generated tokens, session IDs, or keys are long enough (e.g., 128 bits or higher). A larger random space makes it significantly harder for attackers to guess or brute-force the values.
- **Avoid Hardcoded or Predictable Values**
  Do not generate random values based on predictable inputs like timestamps, usernames, or incremental counters**.**
- **Implement Rate Limiting**
  Apply rate limiting on authentication or token verification endpoints to prevent brute-force attacks that try to guess random values repeatedly.
- **Use Secure Libraries and Frameworks**
  Rely on well-tested security libraries instead of writing custom random generation logic.

Vulnerability Name:
Use of Hard-coded Cryptographic Key

CWE
-Key Exchange without Entity Authentication

OWASP Category:
A07-2017: Cross-site Scripting (XSS)

Description:
The product uses a hard-coded, unchangeable cryptographic key

Business Impact:

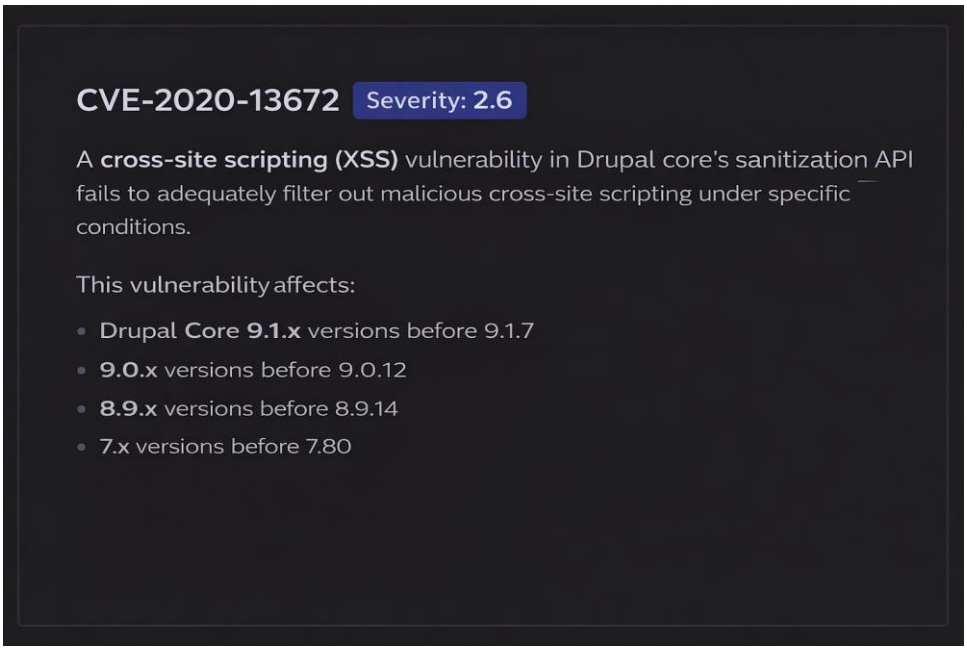
If hard-coded cryptographic keys are used, it is almost certain that malicious users will gain access through the account in question. The use of a hard-coded cryptographic key significantly increases the possibility that encrypted data may be recovered.

Vulnerability Path; https://cwe.mitre.org/documents/sources/TheCLASPApplicationSecurityProcess

Recommendation:

- **Avoid Hard-coding Keys in Source Code**
  Cryptographic keys should never be embedded directly in application code, configuration files, or scripts. Storing keys in the source code makes them easily accessible to attackers if the code is exposed.
- **Use Secure Key Management Systems**
  Store cryptographic keys in secure key management solutions such as **Hashi Corp Vault**, **AWS Key Management Service**, or **Azure Key Vault** to securely generate, store, and control access to encryption keys.
- **Use Environment Variables or Secure Configuration Storage**
  Instead of hard-coding, retrieve keys from protected environment variables or encrypted configuration storage during runtime.

- **Implement Key Rotation**
  Regularly rotate cryptographic keys and revoke compromised or outdated keys to minimize the impact of potential exposure.



8)Vulnerability name:

Key Exchange without Entity Authentication

CWE

- Key Exchange without Entity Authentication

Description:

Key Exchange without Entity Authentication is a security weakness where cryptographic keys are exchanged between two parties without properly verifying the identity of the communicating entities. Because the system does not authenticate the participants during the key exchange process, an attacker can impersonate one of the parties and establish a connection with the other side**.**

Business Impact:

Without proper authentication during key exchange, attackers can intercept communication and gain access to confidential information such as user credentials, financial data, or internal business records Attackers may exploit this weakness to perform a Man-in-the-Middle Attack, allowing them to intercept, modify, or inject malicious data into the communication between two systems.

Steps to Reproduce: exploit open ports 80 to perform SQL injections, cross-site request forgeries and DDoS attacks.

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ sudo su
[sudo] password for paavan:
┌──(root㉿kali)-[/home/paavan/Desktop]
└─# sudo nmap --top-ports 65536 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
zsh: segmentation fault  sudo nmap --top-ports 65536 31.3.96.40

┌──(root㉿kali)-[/home/paavan/Desktop]
└─# sudo nmap -sV -p 80 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
Nmap scan report for web.mmebvba.com (31.3.96.40)
Host is up (0.043s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.28 seconds

┌──(root㉿kali)-[/home/paavan/Desktop]
└─# msfconsole
```

```
Metasploit tip: Open an interactive Ruby terminal with
irb
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/dos/tcp/synflood
msf6 auxiliary(dos/tcp/synflood) > set RHOST 31.3.96.40
RHOST => 31.3.96.40
msf6 auxiliary(dos/tcp/synflood) > set RPORT 80
RPORT => 80
msf6 auxiliary(dos/tcp/synflood) > RUN
[-] Unknown command: RUN
msf6 auxiliary(dos/tcp/synflood) > run
[*] Running module against 31.3.96.40

[*] SYN flooding 31.3.96.40:80...
```

Recommendation:

- **Implement Strong Authentication During Key Exchange**
  Ensure that both communicating parties verify each other's identity before exchanging cryptographic keys. Use authentication mechanisms such as digital certificates or secure authentication protocols.
- **Use Secure Communication Protocols**
  Implement well-established protocols like Transport Layer Security (TLS) or Secure Shell (SSH) that support authenticated key exchange to prevent unauthorized entities from participating in the communication**.**
- **Apply Certificate-Based Authentication**
  Use trusted certificates issued by recognized certificate authorities such as DigiCert to verify the identity of servers and clients during the key exchange process.
- **Enable Mutual Authentication**
  Configure systems to use mutual authentication so that both the client and server verify each other's identities before establishing a secure session.

9)Vulnerability Name:
Reusing a Nonce, Key Pair in Encryption

CWE-327:
Reusing a Nonce, Key Pair in Encryption

OWASP Category:

A02:2021-Cryptographic Failures

Description:
The product uses a broken or risky cryptographic algorithm or protocol.

Business Impact:
TLS 1.0 is an outdated and vulnerable encryption protocol, and its use can expose sensitive data to potential security threats. This not only jeopardizes the integrity of customer information and payment details but also tarnishes the company's reputation. The business may face legal consequences, loss of customer trust, and decreased revenue as security- conscious users avoid the site due to its security vulnerabilities. Immediate action is necessary to upgrade to a more secure TLS version to safeguard data, ensure compliance, and maintain customer confidence.

Steps to Reproduce:

- Open a terminal or command prompt
- Type the Command: openssl s_client -connect 31.3.96.40:443 -tls1
- The connection is successfully means the server supports TLS 1.0

```
thanmaye08@THANMAYE: ~
File  Actions  Edit  View  Help
┌──(thanmaye08㉿THANMAYE)-[~]
└─$ openssl s_client -connect 31.3.96.40:443 -tls1
CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 CN = web.mmebvba.com
verify error:num=18:self-signed certificate
verify return:1
depth=0 CN = web.mmebvba.com
verify return:1
---
Certificate chain
 0 s:CN = web.mmebvba.com
   i:CN = web.mmebvba.com
   a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
   v:NotBefore: May 25 09:07:54 2015 GMT; NotAfter: May 22 09:07:54 2025 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIICxDCCAaygAwIBAgIJALpeeeDC90PLMA0GCSqGSIb3DQEBCwUAMBoxGDAWBgNV
BAMMD3dlYi5tbWVidmJhLmNvbTAeFw0xNTA1MjUwOTA3NTRaFw0yNTA1MjIwOTA3
NTRaMBoxGDAWBgNVBAMMD3dlYi5tbWVidmJhLmNvbTCCASIwDQYJKoZIhvcNAQEB
BQADggEPADCCAQoCggEBAK/hFlEmVRyv2fbXel6oUukbiGdpX0Xps5sqis2OxF9Y
/YXJcxaPoI/fUyfSdJ6prr2/YoEcUUfZaUIJWbsSz/qzklja0M+GMAVzL+wqAi+V
HjgujqsgeEQgxgTiNoQu9Zld5NY7Ac9qQRKbLBLRubQV/9+Dud0Isx3z1gAsJda6
bi3JuL0a27EMztRssKeQClJhWLAdidjuXH6kc+3jbNPmvedRF+Mw5mk32nNtyZ78
qjIFT7Bny/CNGN31PFgQWq+6pTgCzokui04zV0pYyaGX9hs6roLiQWLT9UqB0wx0
Jr+GM175u2YLvXba+UZ2cWMOp5IZ359OHtkf0uuKSzUCAwEAAaMNMAswCQYDVR0T
BAIwADANBgkqhkiG9w0BAQsFAAOCAQEAgKAHg1qFsUlDarYKIrjuUxfeI2bE1fLd
VGIYBzmaQddzehzBu9Akn9g73DHwrs9+gW9cDfkClVr3ayzS5KAMhvnZzga1B0+q
NYfX2y61SMnS4w9p8PT3iqZdF/RYwu658BXjpJWojwoA8Hu1mhwT0DdSSEofBnIq
azNm62lQsxdTlU7wEanZ0/ExUFNktwKean7Jle3EvH94fkNg2T0er1WuEB/QF6sv
dJqxsYSZ3toPEuqlOryWis0E8pfo3Hauzz6fBGijLcEnMoFp7oCZNz0Xh9Q93aOs
5c9hNmHtQcu3vMrYUYArpj+a/euAEI2HaGJZf5g75mf4gAI/2B7iyg==
-----END CERTIFICATE-----
subject=CN = web.mmebvba.com
issuer=CN = web.mmebvba.com
---
No client certificate CA names sent
Peer signing digest: MD5-SHA1
Peer signature type: RSA
Server Temp Key: ECDH, prime256v1, 256 bits
---
SSL handshake has read 1404 bytes and written 274 bytes
Verification error: self-signed certificate
---
New, TLSv1.0, Cipher is ECDHE-RSA-AES256-SHA
Server public key is 2048 bit
Secure Renegotiation IS supported
Compression: NONE
Expansion: NONE
```

10)Vulnerability Name:

Web config File Information Disclosure

CWE-497:
Exposure of Sensitive System Information to an Unauthorized Control Sphere

OWASP Category:
A3:2017-Sensitive Data Exposure

Description:

An information disclosure vulnerability exists in the remote web server due to the disclosure of the web config file. An unauthenticated, remote attacker can exploit this, via a simple GET request, to disclose potentially sensitive configuration information.

Business Impact:

It exposes sensitive configuration details, including database connection strings and encryption keys, to potential attackers. This could lead to unauthorized access, data breaches, and system compromise. The impact includes financial losses, damage to reputation, and legal liabilities as the organization's security and customer trust are compromised

```
GET /web.config HTTP/1.1
Host: web.mmebvba.com
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*



This produced the following truncated output (limited to 5 lines) :
------------------------------ snip ------------------------------
<?xml version="1.0" encoding="UTF-8"?>
<configuration>
<system.webServer>
<!-- Don't show directory listings for URLs which map to a directory. -->
<directoryBrowse enabled="false" />
[...]
```

Recommendation:

- Implement proper access controls to restrict access to the web.config file.
- Prevent directory traversal and ensure the web.config file cannot be directly accessed through the web server.
- Encrypt sensitive data within the configuration file.
- Regularly review and update the web.config file, removing any unnecessary sensitive information.
- Ensure that the web.config file is properly secured and not accessible to unauthorized users.

Main Website: vtop.vit.ac.in

1)Vulnerability Name: SL Medium Strength Cipher Suites Supported (SWEET32)

CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

OWASP Category: Broken access control

Description:

The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Business Impact:

The vulnerability known as SWEET32 (Short for Sweet 32 Birthday Attack) relates to the continued use of legacy cryptographic cipher suites with 64-bit block sizes in TLS and SSL protocols. These suites are susceptible to birthday attacks, which exploit the probability of two blocks colliding after a certain number of transactions. If an organisation's systems are vulnerable to SWEET32, it means they're potentially at risk of having encrypted communications intercepted or manipulated. This could lead to unauthorised access, data theft, or even the injection of malicious code. As a result, businesses face a significant risk to the confidentiality and integrity of their sensitive information. Remediation involves updating systems to support more secure cipher suites with larger block sizes, which would effectively mitigate this vulnerability and enhance the overall security posture. Failure to address SWEET32 could leave an organisation exposed to increasingly sophisticated attacks and legal consequences due to potential data breaches.

Vulnerability Path :

The Sweet32 vulnerability when detected with a vulnerability scanner will report it as a CVSS 7.5.

Steps to Reproduce:

HIGH SSL Medium Strength Cipher Suites Supported (SWEET32)

Description

The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Solution

Reconfigure the affected application if possible to avoid use of medium strength ciphers.

See Also

https://www.openssl.org/blog/blog/2016/08/24/sweet32/
https://sweet32.info

Output

```
Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

  Name                        Code           KEX          Auth     Encryption             MAC
  ----------------------      ----------     ---          ----     ---------------------  ---
  EDH-RSA-DES-CBC3-SHA        0x00, 0x16     DH           RSA      3DES-CBC(168)          SHA1
  ECDHE-RSA-DES-CBC3-SHA      0xC0, 0x12     ECDH         RSA      3DES-CBC(168)          SHA1
  DES-CBC3-SHA                0x00, 0x0A     RSA          RSA      3DES-CBC(168)          SHA1

The fields above are :

  {Tenable ciphername}
  {Cipher ID code}
  Kex={key exchange}
  Auth={authentication}
  Encrypt={symmetric encryption method}
  MAC={message authentication code}
  {export flag}
```

To see debug logs, please visit individual host

Port	Hosts
443 / tcp / www	136.233.9.22

Plugin Details

Severity:	High
ID:	42873
Version:	1.21
Type:	remote
Family:	General
Published:	November 23, 2009
Modified:	February 3, 2021

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: PoC
Age of Vuln: 730 days +
Product Coverage: High
CVSSV3 Impact Score: 3.6
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 6.1
Risk Factor: Medium
CVSS v3.0 Base Score 7.5
CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CVSS v2.0 Base Score: 5.0
CVSS v2.0 Vector:
CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N

Vulnerability Information

Vulnerability Pub Date: August 24, 2016

Recommendation: organisations should take several proactive steps. Firstly, it is crucial to update and configure cryptographic libraries, web servers, and any network devices to disable support for cipher suites with 64-bit block sizes. This can be achieved by ensuring that only modern and secure cipher suites are enabled in the TLS/SSL configurations. Additionally, organizations should regularly monitor and assess their systems for any outdated or vulnerable protocols and promptly apply security patches and updates. Implementing strong, unique encryption keys and employing forward secrecy protocols can further bolster security. It's also recommended to utilize intrusion detection systems and perform regular security audits to identify and address any potential vulnerabilities promptly. Lastly, organizations should stay informed about emerging security threats and best practices in cryptographic protocols to proactively adapt their security measures. By taking these measures, businesses can significantly reduce the risk of falling victim to SWEET32 attacks and enhance the overall security of their digital infrastructure.

2)Vulnerability Name: Cookie SERVERID created without secue flag

CWE-79: Improper Neutralization of Input During Web Page Generation

OWASP Category: A07-2017: Cross-site Scripting

Description:

The vulnerability allows an attacker to inject malicious code into a WordPress website, which can then be executed by visitors to the website.To exploit this vulnerability, an attacker would simply need to trick a user into clicking on a malicious link or opening a malicious attachment. Once the user clicks on the link or opens the attachment, the attacker's code would be executed, giving the attacker control over the user's account and potentially the entire WordPress website.

Business Impact:

The business consequences of XSS can be severe, ranging from reputational damage due to compromised customer trust, to legal repercussions in cases of data breaches.Moreover, it can lead to financial losses through fraud or the cost of remediation efforts. Beyond the immediate impacts, long-term harm may occur if customers abandon the platform due to security concerns. To mitigate CWE-79, businesses must implement rigorous input validation and output encoding practices, as well as stay vigilant for emerging threats in web application security. Failure to address XSS vulnerabilities could result in significant harm to both the business's reputation and its bottom line.

Vulnerability Path: https://securityheaders.com/

Steps to Reproduce:

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

1. **Update and Patch:** Ensure that Drupal and all related modules and components are up to date with the latest security patches to mitigate known vulnerabilities.
2. **Input Validation:** Implement strong input validation and output encoding to sanitize user inputs and prevent the injection of malicious scripts.
3. **Content Security Policy (CSP):** Implement CSP headers to restrict the sources from which content can be loaded, reducing the risk of XSS.
4. **Secure Coding Practices:** Train developers in secure coding practices, emphasizing the importance of validating and escaping user inputs.
5. **Security Scanning:** Conduct regular security scans and penetration tests to identify and address XSS vulnerabilities.

3)Vulnerability Name: X-Content-Type Options Header Missing

CWE-918: Server-Side Request Forgery (SSRF)

OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF)

Description:

The absence of the "X-Content-Type-Options" header poses a notable security risk for web applications. This header is a crucial security feature that instructs the browser to interpret files with a MIME type as declared in the Content-Type header, rather than trying to guess the type. When this header is missing, the browser may attempt to infer the content type, leaving room for potential misinterpretation and security vulnerabilities like MIME-sniffing attacks. This could enable attackers to disguise malicious content, such as scripts or executable files, as benign content, leading to Cross-Site Scripting (XSS) or other types of attacks.Implementing the "X-Content-Type-Options" header with the value "nosniff" is a fundamental security measure that helps prevent these risks. It ensures that browsers strictly adhere to the declared content type, enhancing the overall security posture of the web application and safeguarding against potential exploitation stemming from content misinterpretation.

Business Impact:

The header missing impact Data Exposure(Attackers might force the server to render sensitive data as HTML, leading to data exposure),Security Risks(Content type manipulation can increase security risks, potentially leading to breaches, data leaks, and unauthorized access), Brand and Reputation Damage(Successful attacks that exploit SSRF vulnerabilities can harm the organization's reputation and trustworthiness)

Vulnerability Path :

https://securityheaders.com/?q=http%3A%2F%2Fvtop.vit.ac.in%2F&followRedirects=on

Steps to Reproduce:

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

- Implement "X-Content-Type-Options" Header: Configure the "X-Content-Type-Options" header with the value "nosniff" in your web server or application to prevent content type sniffing.
- Secure SSRF: To directly mitigate SSRF vulnerabilities, ensure proper input validation, access controls, and allow-list-based URL validation to prevent attackers from making unauthorized requests to internal resources.
- Security Headers: Implement other security headers like "X-Frame-Options" and "Content-Security-Policy" to further enhance security and mitigate various types of web-based attacks.

While the "X-Content-Type-Options" header may not be a direct countermeasure to SSRF, it is a valuable security control that, when configured correctly, can help protect against content type-based attacks that may be exploited in SSRF scenarios.

4)Vulnerability Name: Denial of Service

CWE - 400: Uncontrolled Resource Consumption

Description:

The Denial of Service (DoS) attack is focused on making a resource (site, application, server) unavailable for the purpose it was designed. There are many ways to make a service unavailable for legitimate users by manipulating network packets, programming, logical, or resources handling vulnerabilities, among others. If a service receives a very large number of requests, it may cease to be available to legitimate users. In the same way, a service may stop if a programming vulnerability is exploited, or the way the service handles resources it uses.Sometimes the attacker can inject and execute arbitrary code while performing a DoS attack in order to access critical information or execute commands on the server. Denial-of-service attacks significantly degrade the service quality experienced by legitimate users. These attacks introduce large response delays, excessive losses, and service interruptions, resulting in direct impact on availability.

Business Impact:

If successfully exploited, it involves overwhelming a system or application with excessive demands on its resources. This can lead to a range of disruptive consequences. The targeted system may experience significant slowdowns, or even complete unresponsiveness, making it difficult or impossible for legitimate users to access. Critical resources like CPU, memory, and network bandwidth can become depleted, causing further degradation in performance. In severe cases, the exploited vulnerability may lead to system crashes or failures, potentially resulting in data loss. This disruption not only impacts business productivity and financial stability but also risks reputational damage, eroding customer trust and confidence.Additionally, organizations may face regulatory compliance issues if the uncontrolled resource consumption leads to violations of service level agreements or industry standards. Mitigating this vulnerability requires proactive resource management practices and a well-prepared incident response plan to minimize the potential impacts on business operations and customer satisfaction.

Steps to Reproduce: exploit open ports 443 to perform SQL injections, cross-site request forgeries and DDoS attacks.

```
┌──(root㉿kali)-[/home/paavan]
└─# nmap -O vtop.vit.ac.in
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-19 18:27 IST
Nmap scan report for vtop.vit.ac.in (136.233.9.22)
Host is up (0.044s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
465/tcp  closed smtps
3306/tcp closed mysql
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X|5.X (89%), Apple macOS 10.13.X (86%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5.1 c
Aggressive OS guesses: Linux 3.10 - 4.11 (89%), Linux 5.1 (87%), Apple macOS 10.13 (High Sierra
85%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.27 seconds
```

```
┌──(root㉿kali)-[/home/paavan]
└─# msfconsole

       =[ metasploit v6.3.27-dev                          ]
+ -- --=[ 2335 exploits - 1220 auxiliary - 413 post       ]
+ -- --=[ 1385 payloads - 46 encoders - 11 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit tip: Adapter names can be used for IP params
set LHOST eth0
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/dos/tcp/synflood
msf6 auxiliary(dos/tcp/synflood) > set RHOST 136.233.9.22
RHOST => 136.233.9.22
msf6 auxiliary(dos/tcp/synflood) > set RPORT 443
RPORT => 443
msf6 auxiliary(dos/tcp/synflood) > exploit
[*] Running module against 136.233.9.22

[*] SYN flooding 136.233.9.22:443...
^C[-] Stopping running against current target...
[*] Control-C again to force quit all targets.
[*] Auxiliary module execution completed
msf6 auxiliary(dos/tcp/synflood) >
```

Recommendation: employ a robust Web Application Firewall (WAF) capable of filtering and mitigating suspicious traffic targeting port 80. Configure it to block excessive requests or patterns indicative of an attack. Utilise load balancing techniques to distribute traffic across multiple servers, ensuring no single server becomes overwhelmed. Additionally, implement rate limiting and throttling mechanisms to restrict the number of requests a single IP address can make within a defined time frame. Regularly monitor traffic patterns and set up alerts to detect unusual spikes in activity, enabling rapid response to potential attacks. Finally, keep software and systems up-to-date with the latest security patches to address known vulnerabilities that attackers may exploit.

OWASP Category: A02:2021-Cryptographic Failures

Description: Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP, SNMP, etc.), it is possible to guess the name of the remote operating system in use. It is also possible sometimes to guess the version of the operating system.

Business Impact: If sensitive information is improperly handled or inadequately protected, it can lead to financial losses, regulatory penalties, and damage to reputation. Customers may lose trust in the organization's ability to safeguard their data, potentially resulting in a loss of business and market share. Legal consequences and compliance issues may arise, leading to additional costs. Moreover, intellectual property theft or exposure can compromise a company's competitive edge. Remediation efforts, including implementing stronger security measures and compensating affected parties, can also entail substantial expenses. Overall, CWE-200 highlights the critical importance of robust data protection measures to safeguard an organization's financial health, reputation, and long-term viability.

Steps to Reproduce: use nmap -O TARGET to enable os detection

Recommendation:

implementing robust encryption protocols for data both in transit and at rest, coupled with stringent access controls and strong authentication measures. Regular vulnerability assessments and penetration testing should be conducted to identify and rectify potential weak points. Educating employees through comprehensive security awareness training is vital, emphasising proper data handling practices and recognition of potential threats. Employing data masking techniques for non-production environments and utilising advanced Data Loss Prevention (DLP) solutions can further fortify defences. Additionally, maintaining compliance with relevant data protection laws and regulations, as well as establishing a well-defined incident response plan, are crucial components of a comprehensive strategy to safeguard against sensitive information exposure.

Conclusion for stage 1

Stage 1 focuses on web application testing and security analysis. In this stage, the OWASP Top 10 is used as a reference to identify and understand common security vulnerabilities. The OWASP Top 10 is a globally recognized list that highlights the most critical security risks affecting web applications. Studying these vulnerabilities helps security testers and developers recognize potential threats and implement appropriate measures to protect web applications from attacks

Stage 2

Overview :-

Nessus is a widely used **vulnerability scanning tool** developed by **Tenable, Inc.** It is a remote scanning tool, which means it does not need to be installed on the target system in order to perform a scan. Instead, Nessus identifies security weaknesses by sending different types of probes to the target host. These probes may include network traffic, operating system commands, and application-level requests.

Nessus follows a **plugin-based architecture**. Plugins are small programs designed to detect specific vulnerabilities in systems. Currently, Nessus includes **more than 1200 plugins**, which help identify vulnerabilities in operating systems, applications, and network devices.

During the scanning process, Nessus first performs a **discovery phase** to identify the operating system and services running on the target host. After identifying these details, Nessus executes various plugins to check for potential vulnerabilities. When a vulnerability is detected, Nessus generates a detailed report that includes the **severity level, steps to reproduce the vulnerability, and recommended remediation measures**.

Nessus can scan different types of targets, including **individual hosts, entire networks, and web applications**. It also allows users to scan **specific ports and services**. Scans can be performed **manually or scheduled to run automatically** at specific times.

Working Process of Nessus

The vulnerability scanning process in Nessus typically follows these steps:

1. Nessus connects to the target system using protocols such as **TCP, UDP, and ICMP**.
2. It sends multiple probes to the target host to identify the **operating system and active services**.
3. Nessus then runs appropriate **plugins to detect known vulnerabilities** in the system.
4. After the scanning process is completed, Nessus generates a **comprehensive report** that includes the severity of each vulnerability, along with reproduction steps and recommended solutions.

Benefits of Using Nessus

- **Comprehensive Vulnerability Detection:** Nessus includes over **1200 plugins** that help detect vulnerabilities across operating systems, applications, and network devices.
- **User-Friendly Interface:** The tool provides an easy-to-use interface that simplifies configuration and scanning.
- **Detailed Reporting:** Nessus generates comprehensive reports containing vulnerability severity levels, reproduction steps, and remediation guidance.
- **Scalability:** It can scan **single hosts, networks, and web applications**, making it suitable for various environments.
- **Flexible Configuration:** Users can perform scans **manually or schedule them automatically** based on security requirements.

Overall, Nessus is a powerful and reliable tool that helps security professionals identify and address vulnerabilities within their networks. By using Nessus, organizations can strengthen their security posture and prioritize remediation efforts effectively.

Target Details

Target Website : http://zero.webappsecurity.com/

Target IP Address: 54.82.22.214

\

s.no	Vulnerability name	Severity	plugins
1	Ping the Remote Host	INFO	10180

Severity **gin ID**

REPORT: -

Vulnerability Name: - 10180 – Ping the Remote Host

Severity: - INFO

Plugin: - 10180

Port: - 443

Description:

Nessus was able to determine if the remote host is alive using one or more of the following ping types :

- An ARP ping, provided the host is on the local subnet and Nessus is running over Ethernet.

- An ICMP ping.

- A TCP ping, in which the plugin sends to the remote host a packet with the flag SYN, and the host will reply with a RST or a SYN/ACK.

- A UDP ping (e.g., DNS, RPC, and NTP).

Stage-3

Title: - Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

Legacy Authentication Challenges:

- Before the integration of Zscaler with Identity Providers (IdP), many organizations relied on traditional authentication methods such as VPN-based access. These legacy systems created several security, performance, and management issues. In traditional VPN architecture, once a user successfully authenticates, the system continues to trust the user without further verification. This model provides users with broad network-level access, which can lead to excessive permissions. As a result, attackers who gain access to one system may move laterally across the network and target other systems.
- Additionally, VPN gateways must be exposed to the public internet through open ports, making them vulnerable to cyber threats such as port scanning, brute-force login attempts, and exploitation of security vulnerabilities. Another major challenge is poor user experience caused by traffic hair-pinning, where remote user traffic is first routed through the organization's data center before accessing the internet, resulting in increased latency and slower performance.
- Traditional VPN solutions also depend on hardware appliances that have fixed capacity limits. During periods of high usage, organizations must manually upgrade or expand these systems. IT teams are also responsible for continuously patching, upgrading, and maintaining these physical devices, which increases operational workload. Furthermore, legacy authentication systems often do not integrate well with modern identity providers, forcing administrators to maintain multiple user accounts across different platforms. Because of these limitations, organizations are increasingly adopting a modern identity-centric approach where authentication is handled by enterprise identity providers and access decisions are based on user identity rather than network location.

Zero Trust Identity Principles:

- The integration of Zscaler with Identity Providers (IdPs) is based on the concepts of Zero Trust Architecture, which changes the traditional approach to authentication and authorization. The main idea of Zero Trust is “never trust, always verify.” This means that every access request must be properly authenticated and validated, whether the user is working inside the office network or remotely.
- Another important principle is least privilege access, where users are given only the minimum level of access required to perform their tasks. Instead of relying on network location, access is controlled through identity-based policies. The concept of assume breach also plays a key role, where the system is designed with the assumption that attackers may already exist within the network. Because of this, all sessions are continuously verified.
- Micro-segmentation is used to separate users and applications to prevent attackers from moving across different systems within the network. Rather than giving access to the entire network, users are connected only to the specific applications they need. In this model, identity becomes the main security boundary, replacing the traditional approach where the internal network was automatically trusted.
- Authentication decisions are made using multiple contextual factors such as user identity, device condition, location, and user behavior. Authorization is also determined dynamically through real-time risk evaluation instead of fixed rules. These Zero Trust principles guide the integration between Zscaler and Identity Providers, creating a security framework where identity acts as the central control point and access is provided on an application-by-application basis rather than full network access.

Supported Identity Providers and Protocols:

- Zscaler can integrate with a wide variety of Identity Providers (IdPs) using standard authentication protocols, which makes it adaptable for different enterprise environments. One commonly used integration is with Microsoft Entra ID (Azure AD), where SAML 2.0 is used for federated authentication and SCIM is used for automatic user provisioning. This integration allows organizations to take advantage of Azure AD features such as Conditional Access policies and detailed reporting.
- Zscaler also supports integration with Okta, which uses OpenID Connect (OIDC) for modern authentication and SCIM for managing the user lifecycle. Okta provides ready-made connectors through the Okta Integration Network (OIN), making the setup process easier and faster.
- For organizations that still use on-premises Active Directory, Zscaler provides a solution called the Zscaler Authentication Bridge (ZAB). This is a lightweight connector that enables secure LDAP communication between Zscaler's cloud platform and internal domain controllers. The ZAB connector operates from behind the firewall and creates outbound connections to Zscaler, which removes the need for inbound firewall rules. It handles authentication requests and synchronizes user group information securely.
- In addition to these, Zscaler also supports other identity providers such as Ping Identity, OneLogin, and other generic SAML 2.0 providers, allowing organizations to continue using their existing identity management systems. Zscaler supports multiple authentication protocols including SAML 2.0 for web-based Single Sign-On (SSO), OIDC for modern and mobile applications, LDAP for on-premises directory services, and SCIM 1.1/2.0 for automated user provisioning. This multi-protocol support ensures smooth and secure access across different applications, devices, and user environments.

Prerequisites and Licensing Requirements:

- To successfully implement Zscaler–IdP integration, certain prerequisites and licensing requirements must be fulfilled before starting the deployment. Organizations must have an active subscription to Zscaler Internet Access (ZIA) and/or Zscaler Private Access (ZPA) with the required number of user licenses. These licenses should support features such as Single Sign-On (SSO) and SCIM-based user provisioning**.**
- Administrators also need access to the Zscaler Admin Portal with Super Admin privileges or other suitable administrative roles to configure authentication settings and manage identity provider integrations. When integrating with cloud-based identity providers such as Microsoft Entra ID (Azure AD) or Okta, administrative permissions are required to create enterprise applications, configure SAML authentication endpoints, and enable API permissions for SCIM provisioning.
- For organizations using on-premises Active Directory, a Windows Server system is needed to install and run the Zscaler Authentication Bridge (ZAB). This server must have outbound internet connectivity to communicate with Zscaler cloud services. From a network perspective, firewall settings must allow outbound HTTPS (TCP port 443) traffic from the ZAB server to Zscaler cloud endpoints, as well as from user devices to Zscaler enforcement nodes.
- In addition, proper DNS configuration is necessary to resolve Zscaler services and internal domain controllers. SSL certificate management is also important, especially if organizations choose to use their own certificates for SAML assertion signing instead of default Zscaler-generated certificates. Finally, user attributes such as email ID, User Principal Name (UPN), and group memberships must be planned in advance because these attributes are used for policy enforcement and application access control.

Discovery and Requirements Gathering:

- The discovery phase is an important step in the integration process because it helps organizations understand their current identity systems and access requirements. During this stage, all internal applications that are currently accessed through legacy VPN solutions are identified and documented. These may include systems such as student information systems, ERP applications, library platforms, research computing resources, internal file servers, and administrative portals.
- For every application, important technical details must be recorded, including the communication protocol (such as HTTP/HTTPS, RDP, SSH, or SMB), port numbers, IP addresses or hostnames, and the specific group of users who require access to those applications.
- User segmentation is also performed during this phase to organize users into logical groups based on their roles and responsibilities. For example, faculty members may require access to research servers, students may need access to library resources, staff may use administrative portals, IT administrators may manage server infrastructure, and external collaborators may require restricted access to specific applications.
- In addition, organizations must review their existing identity sources, such as Azure Active Directory, Okta, or on-premises Active Directory, to determine which system acts as the main source for user authentication. The current authentication methods must also be analyzed, including multi-factor authentication (MFA) requirements, password policies, and any existing Single Sign-On (SSO) implementations.

Identity Source Architecture Planning:

- Planning the identity source architecture is an important step to determine which directories will act as the main source of identity information for different groups of users. In organizations that use a hybrid identity environment, it is necessary to decide whether Azure Active Directory (Azure AD) will function as the primary authentication source with synchronization from on-premises Active Directory using Azure AD Connect, or whether direct integration with on-premises AD through the Zscaler Authentication Bridge (ZAB) will be used for certain scenarios.
- The directory synchronization structure must also be documented, including which user attributes are synchronized, how user groups are maintained, and how frequently directory updates occur. Proper attribute mapping between the identity provider's directory schema and Zscaler user attributes is essential. Important fields such as User Principal Name (UPN), email address, given name, surname, and group membership should be correctly mapped to ensure accurate authentication and policy enforcement.
- For Azure AD integration, organizations must choose between SAML-based authentication with optional SCIM provisioning or OpenID Connect (OIDC) for modern authentication needs. When integrating with Okta, the Okta Universal Directory schema should be planned, and the user profile attributes that will be shared with Zscaler during authentication and provisioning should be identified.
- If on-premises Active Directory is integrated using ZAB, it is important to document the locations of domain controllers, evaluate network latency between sites, and plan for high availability of the ZAB connector. Disaster recovery strategies should also be considered, such as failover between identity providers and options for maintaining access during outages.
- Finally, organizations should plan a phased migration strategy, where small pilot user groups are moved first from legacy authentication systems to the Zscaler–IdP integration, followed by a gradual rollout to all users in the production environment.

Application Discovery and Categorization:

- The application discovery process helps organizations identify all the resources that need secure access before configuring security policies. This step ensures that every internal application used by remote users is properly documented and protected. Network monitoring tools or firewall log analysis can be used to review application access over the last few months, usually around 90 days, to identify commonly used services.
- For each discovered application, important technical details should be recorded such as the Fully Qualified Domain Name (FQDN) or IP address, transport protocol (TCP or UDP), port number, and the type of application (for example web applications, RDP, SSH, SMB, or database services).
- It is also important to communicate with application owners and department managers to confirm the discovered applications and identify any shadow IT resources that may not appear in system logs. Once the applications are identified, they should be categorized based on their sensitivity level, such as public information, internal-use applications, confidential systems, or restricted resources. This helps determine the level of security policies required for each application.
- Organizations must also analyze application dependencies, such as systems that rely on backend databases or authentication services, so that proper segmentation can be applied without affecting functionality. Some applications may run on shared infrastructure, like multiple virtual hosts on a single server, but may still require different access policies.
- To manage this information effectively, an application inventory document can be created that includes details such as application name, description, department owner, technical contact, protocol, port number, destination IP or FQDN, user groups, sensitivity classification, and any special access requirements. The final list should be verified with the IT operations team to ensure that no important systems are missed. Applications can then be prioritized for initial ZPA configuration based on their business importance and reliance on VPN access.

User Group Definition and Attribute Planning:

- Defining user groups and planning directory attributes is an important step for creating detailed access control policies in Zscaler. Organizations should work with HR teams and department managers to identify different user roles that require specific access permissions. Examples of such roles may include faculty members, adjunct faculty, administrative staff, student workers, graduate researchers, undergraduate students, IT administrators, and external consultants**.**
- Once the roles are identified, the relationship between organizational roles and directory groups should be clearly documented. These groups may be synchronized from on-premises Active Directory, managed directly in Azure Active Directory, or maintained within Okta, depending on the identity management system used by the organization.
- To simplify policy management, organizations can design group nesting structures. For example, a main group such as “All Faculty” can include smaller subgroups representing individual departments. This hierarchical structure makes it easier to manage and apply access policies.
- It is also necessary to identify important user attributes that will be used to enforce policies. Common attributes include department name, job title, location, employee type, manager information, and start or end dates for temporary employees. In addition, some attributes may have multiple values, such as group memberships, which can be used to dynamically assign policies and control user access more effectively.
- Organizations should also plan for Just-In-Time (JIT) provisioning, where user accounts are automatically created in Zscaler when a user logs in for the first time, instead of creating all accounts in advance. This approach helps simplify user management and reduces administrative work.
- In some cases, attribute transformation rules may be required if the directory attributes need to be modified before being used in Zscaler. For example, a username stored in the format domain\username may need to be converted into user@domain format for proper authentication and compatibility.
- Additionally, it is important to prepare a group-to-application access matrix, which clearly defines which user groups are allowed to access specific applications. This matrix should

also specify the level of permissions granted to each group, such as read-only access or read-write access, depending on the user's role and responsibilities.

- Finally, the defined user groups and their access permissions should be reviewed and confirmed with application owners to ensure that the planned access policies match the organization's business and operational requirements.

Infrastructure Readiness Assessment:

- The infrastructure readiness assessment is performed to ensure that the existing IT environment can properly support the integration between Zscaler and Identity Providers without causing performance or reliability problems. This process involves evaluating the network, systems, and security infrastructure before implementation.
- First, organizations should examine network bandwidth and latency between user locations and the nearest Zscaler data centers. Tools provided by Zscaler can help identify the closest data center and determine whether any network routing improvements are required for better performance.
- Next, existing firewall and proxy configurations should be reviewed to ensure that outbound HTTPS traffic to Zscaler cloud domains such as *.zscloud.net, *.zscaler.net, and *.zscaler.com is allowed. It is also important to avoid SSL inspection on these connections, as it may disrupt authentication processes.
- The organization's DNS infrastructure should also be evaluated to confirm that it can correctly resolve both Zscaler service domains and internal application hostnames. In some cases, split DNS configurations may be required if the same domain names are used for both internal and external access.
- Additionally, the capacity of the virtual infrastructure should be checked before deploying Zscaler App Connectors, including available CPU, memory, and storage resources required to handle the expected number of connections. High availability planning is also important, which may involve deploying multiple App Connectors across different systems or locations to prevent service interruptions.
- The readiness of the identity provider infrastructure should also be assessed, including the authentication capacity of Azure AD, Okta service limits, and the ability of on-premises domain controllers to handle authentication requests from ZAB. Organizations should also

review endpoint readiness by checking user devices and operating systems to ensure they are compatible with the Zscaler Client Connector.

- Finally, network connectivity tests should be performed from different user locations to Zscaler cloud services to confirm stable communication. Any existing security tools such as proxies, firewalls, or monitoring systems that might interfere with Zscaler traffic should be identified, and necessary configuration exceptions should be planned.

Azure AD Integration: SAML Configuration:

- Setting up SAML-based integration between Azure Active Directory (Azure AD) and Zscaler helps establish a secure trust relationship for user authentication. The process begins by logging into the Azure AD portal and navigating to the Enterprise Applications section. From there, a new application can be created by selecting “New Application” and searching for Zscaler in the application gallery. After selecting the appropriate Zscaler application based on the organization’s Zscaler cloud environment (such as Zscaler, Zscaler2, or Zscaler3), the application is created.
- Next, open the application settings and choose the Single Sign-On (SSO) option, then select SAML as the authentication method. In the Basic SAML Configuration section, the Identifier and Reply URL must be entered using the values provided in the Zscaler Admin Portal under the authentication settings. Generally, the identifier follows a format similar to https://<tenant>.zscloud.net/samlsp/metadata, while the reply URL is typically https://<tenant>.zscloud.net/samlsp/acs.
- After this step, the User Attributes and Claims section should be configured to map Azure AD user attributes with SAML assertions. The Name Identifier should be set to the Persistent format, and the source attribute is usually user.userprincipalname. Additional attributes such as given name, surname, email address, and group membership details should also be included as required for user identification and policy enforcement.
- For group-based access control, security groups can be selected as the source so that the SAML response includes the groups to which a user belongs. Once the configuration is completed and saved, the Federation Metadata XML file can be downloaded from Azure AD. This file is then uploaded into the Zscaler Admin Portal to finalize the trust relationship between Azure AD and Zscaler. Before moving forward, it is recommended to

test the SAML configuration using Azure AD's testing feature to ensure that the authentication process works correctly.

Azure AD Integration: SCIM Provisioning Setup:

- Configuring SCIM provisioning between Azure Active Directory (Azure AD) and Zscaler helps automate user management processes. Through this integration, user accounts can be automatically created, updated, and removed in Zscaler based on changes made in Azure AD.
- To begin, open the Zscaler enterprise application in Azure AD and navigate to the Provisioning section from the left menu. Select "Get Started" and set the Provisioning Mode to Automatic. After this, enter the Tenant URL using the SCIM endpoint available in the Zscaler Admin Portal under the SCIM configuration settings. This endpoint usually follows the format https://<tenant>.zscloud.net/scim**.**
- Next, copy the Secret Token from the Zscaler SCIM configuration page and paste it into the required field in Azure AD. Use the Test Connection option to confirm that Azure AD can successfully communicate with Zscaler. Any errors identified during this step should be resolved before continuing.
- After the connection is verified, configure attribute mappings by opening the Mappings section and selecting the option to provision Azure AD users. Review the default attribute settings and adjust them if necessary to ensure that Azure AD attributes correctly match the Zscaler user schema. For example, userPrincipalName should map to userName, and the email attribute should map to the work email value. Group membership attributes should also be properly configured to support access policies.
- To enable group provisioning, review the group mapping settings and ensure that Azure AD groups are correctly linked to Zscaler groups. This allows Zscaler policies to be applied based on user group membership. For a controlled deployment, the provisioning scope can be set to "Sync only assigned users and groups." Pilot users and groups can then be assigned to the application through the Users and Groups section.
- Additional settings such as notification emails for provisioning failures and the provisioning interval (commonly around 40 minutes) should also be configured. Finally, start the provisioning process by selecting "Start provisioning." Monitor the provisioning

logs to check for errors and confirm that test users appear correctly in the Zscaler Admin Portal with the appropriate attributes and group memberships before expanding the deployment to more users.

Okta Integration: OIDC Application Configuration:

- Integrating Okta with Zscaler using OpenID Connect (OIDC) provides a modern and secure authentication method that supports API-based and web-based access. To configure this integration, log in to the Okta Admin Console and navigate to Applications, then select Create App Integration.
- During the setup process, choose OIDC – OpenID Connect as the sign-in method and select Web Application as the application type. After that, provide a suitable name for the application, such as "Zscaler," and continue to the next step.
- In the configuration settings, enter the Sign-in Redirect URI using the callback URL provided in the Zscaler Admin Portal under the OIDC authentication settings. This URL usually follows a format similar to https://<tenant>.zscloud.net/oidc/callback. If single logout functionality is required, a Sign-out Redirect URI can also be configured.
- Access to the application can be controlled by assigning it to specific users or user groups, which is useful during the pilot testing phase. Next, enable the required API scopes such as openid, profile, email, groups, and offline_access, which allow Zscaler to retrieve user identity information during authentication.
- In the Sign-On settings, note the Client ID and Client Secret, as these credentials are required when configuring the Okta identity provider within Zscaler. Under the General Settings section, the login initiation URL should be configured to point to the organization's Zscaler tenant URL.
- Organizations may also apply authentication policies, such as enabling multi-factor authentication (MFA), to improve the security of user access. For integration with Zscaler, administrators should record the Okta domain URL (for example, https://<okta-domain>.okta.com) or download the metadata information required for configuration.
- Finally, the configuration should be tested by accessing the application's sign-in link to confirm that authentication works correctly. During testing, verify that important user

details such as name, email address, and group membership information are correctly included in the ID token, allowing Zscaler to apply the appropriate access policies.

On-Premises AD Integration: ZAB Deployment:

- The Zscaler Authentication Bridge (ZAB) is used to establish secure communication between Zscaler cloud services and on-premises Active Directory through LDAP. This method allows authentication requests to be processed without opening inbound firewall ports, improving security.
- The deployment process begins by downloading the ZAB installation package from the Zscaler Admin Portal under the authentication configuration section. After downloading, administrators must prepare Windows Server virtual machines to host the ZAB service. For better reliability and high availability, at least two servers are recommended. These servers should run Windows Server 2016 or a later version and be configured with approximately 4 virtual CPUs, 8 GB RAM, and 100 GB storage, along with outbound internet connectivity through TCP port 443 to communicate with Zscaler cloud services.
- The servers should also be joined to the Active Directory domain and capable of communicating with domain controllers through standard LDAP ports such as 389 for LDAP **or** 636 for secure LDAP (LDAPS). Once the environment is ready, the ZAB installer can be executed with administrative privileges. During installation, the administrator must enter the Zscaler cloud name and provide the authentication token obtained from the Zscaler Admin Portal.
- By default, the ZAB service runs using the Network Service account, but in many cases it may be configured to run under a domain service account with appropriate permissions to read LDAP data from the domain controllers. After installation, administrators should confirm that the ZAB service is running correctly and has established communication with Zscaler. This can be verified by checking the ZAB log file located in the installation directory.
- In the Zscaler Admin Portal, administrators can check the ZAB configuration page to ensure the connector appears with a “Connected” status. The next step is to configure the LDAP directory settings, including the domain controller addresses, LDAP port number, and base distinguished name (DN) used for searching user accounts.

- To confirm proper configuration, a test user search can be performed from the Zscaler portal to verify that user data is retrieved successfully. For high availability, multiple ZAB connectors can be deployed so that authentication requests are distributed across them automatically. Administrators can monitor the health of these connectors through the Zscaler dashboard and set up alerts to detect any connection failures or service interruptions.

Conclusion:

In conclusion, the study of AI-based web security using IBM QRadar and Zero Trust architecture provided valuable insights into modern cyber security practices through different stages of analysis and implementation.

In **Stage 1**, the concept of web application testing was explored, highlighting the importance of identifying vulnerabilities and protecting web applications from potential security threats. Understanding the fundamentals of vulnerability testing helped build a strong foundation for evaluating the security of web-based systems.

In **Stage 2**, the analysis of Nessus vulnerability reports demonstrated how detailed scanning and reporting can help identify security weaknesses in an organization's infrastructure. Reviewing these reports allows security teams to understand potential risks and implement appropriate mitigation strategies to strengthen system security.

In **Stage 3**, the project focused on replacing the traditional VPN-based network architecture with a modern cloud-based Zero Trust solution using Zscaler. This transformation shifts the security model from a network-centered approach to an application-centered access model. By implementing Zscaler Private Access (ZPA), users are granted access only to specific applications after verifying their identity and device status. This approach eliminates the exposure of internal networks and reduces the risk of lateral movement attacks, thereby significantly improving the organization's overall security posture. Additionally, the cloud-based architecture improves user experience by providing faster and more reliable access for both on-site and remote users.

Looking toward the future scope, Stage 1 highlighted the growing role of Artificial Intelligence in web application security testing. Advanced AI-driven tools have the potential to enhance vulnerability detection and improve the efficiency of security testing processes.

Similarly, **Stage 2** suggested that the future of vulnerability assessment will involve greater automation and AI integration, enabling faster and more accurate detection of security threats while strengthening the overall cyber security framework.

Finally, **Stage 3** demonstrated how integrating Zscaler with enterprise Identity Providers can establish a unified identity management system that replaces legacy VPN infrastructure with a Zero Trust security model. This integration enables Single Sign-On (SSO) across Zscaler services, while enforcing strong security controls such as Multi-Factor Authentication (MFA) and context-based access policies. Automated user provisioning through SCIM simplifies user management and ensures immediate removal of access when users leave the organization. By implementing identity-based micro-segmentation, users are connected only to the applications they need, preventing unauthorized access within the network. Using widely accepted protocols such as SAML, OIDC, and LDAP, the system maintains compatibility with existing identity infrastructure while enabling secure cloud-based access. This integration not only enhances security through continuous monitoring and detailed audit logging but also creates a strong foundation for future identity-driven cyber security strategies based on Zero Trust principles**.**

Future Scope:

Future of Web Application Testing:

- The future of Web Application Testing (WAT) is very promising as modern web applications continue to grow in complexity and functionality. Many organizations rely heavily on web-based systems to manage their operations, making it essential to ensure that these applications remain secure, reliable, and efficient. As technology evolves, several trends are expected to shape the future development of web application testing.
- One of the major trends is the growing importance of security testing. Cyber threats and attacks targeting web applications are increasing, which makes security a top priority for organizations. In the coming years, web application testing will focus more on identifying vulnerabilities and protecting applications from potential security breaches.
- Another significant trend is the increasing use of Artificial Intelligence (AI) and Machine Learning (ML) in testing processes. These technologies can automate repetitive tasks such as test case creation and execution, making testing faster and more efficient. AI and ML can also help detect unusual patterns and potential vulnerabilities that may not be easily identified using traditional testing methods.
- There is also a noticeable shift toward cloud-based testing platforms. As many organizations migrate their applications to cloud environments, cloud-based testing solutions are becoming more popular. These platforms provide advantages such as better scalability, flexibility, and cost efficiency compared to traditional testing methods.
- Additionally, there will be a stronger focus on User Experience (UX) testing in the future. Organizations increasingly understand that a secure application must also be easy and convenient for users to operate. Therefore, testing processes will emphasize improving usability, performance, and overall user satisfaction.
- Overall, these advancements will help improve the effectiveness of web application testing and contribute to stronger cyber security practices in the future.

Future Scope of the Testing Process:

The future of the software testing process is expected to expand significantly as modern software systems become more complex and widely used in business operations. Organizations depend on reliable and high-quality software to perform daily activities, which makes effective testing an essential part of software development.

- One important trend shaping the future of testing is the adoption of continuous testing. In this approach, testing is performed throughout the Software Development Life Cycle (SDLC), starting from development and continuing until deployment. Continuous testing helps detect defects at an early stage, reducing the chances of major issues appearing later in the development process.
- Another major advancement is the growing role of Artificial Intelligence (AI) and Machine Learning (ML) in testing activities. These technologies can automate repetitive tasks such as generating and executing test cases. AI and ML can also analyze large amounts of testing data to identify unusual patterns or potential defects that traditional testing techniques may fail to detect.
- The increasing use of cloud-based testing platforms is also an important trend. Many organizations are moving their applications to cloud environments, and cloud-based testing solutions provide benefits such as better scalability, flexibility, and cost efficiency.
- In addition, there will be a greater emphasis on test automation in the future. Automation tools allow test cases to be executed automatically without constant human involvement. This not only saves time and resources but also improves the overall accuracy and efficiency of the testing process.
- Overall, these developments will make the software testing process faster, more reliable, and better suited to meet the demands of modern software systems.

Future Scope of SOC / SIEM:

The integration of Zscaler with enterprise Identity Providers creates many opportunities for future improvements in the organization's security infrastructure. In the future, the system can be expanded by integrating additional Identity Providers such as Ping Identity, OneLogin, and Google Workspace to support different types of users including external collaborators, contractors, and partner institutions.

Advanced conditional access policies can also be implemented by using real-time risk information from threat intelligence platforms. This will allow authentication decisions to adapt dynamically based on the current security risk. Further improvements can be achieved by integrating endpoint detection and response (EDR) solutions such as CrowdStrike, SentinelOne, and Microsoft Defender for Endpoint, which will help evaluate the health and security status of user devices before granting access.

Future enhancements may also include the implementation of Privileged Access Management (PAM) systems to control administrative access. Through this approach, temporary elevated permissions can be granted only when required, with approval workflows and session monitoring for better security and compliance.

Integration with Identity Governance and Administration (IGA) platforms such as SailPoint or Saviynt can improve user access management by enabling automated access reviews and policy compliance checks. In addition, the implementation of advanced Data Loss Prevention (DLP) policies in Zscaler Internet Access (ZIA) can help protect sensitive organizational data from unauthorized sharing or exfiltration.

Security operations can also be strengthened by integrating Security Orchestration, Automation, and Response (SOAR) platforms. This integration will allow automated responses to security incidents detected by Zscaler, reducing response time and improving threat mitigation. Deploying Zscaler across branch offices with SD-WAN integration can further extend identity-based security policies across all network locations.

Another future enhancement is the use of User Behavior Analytics (UBA) to monitor user activity and detect unusual access patterns. This will allow organizations to identify potential threats early and apply additional authentication checks when required. Integration with Human Resource (HR) systems can also automate user lifecycle management processes such as employee onboarding, role changes, and account deactivation.

In addition, the adoption of certificate-based authentication can extend Zero Trust security principles to Internet of Things (IoT) devices and operational technology (OT) systems, ensuring secure communication for non-user entities. Continuous policy optimization using machine learning analysis of access patterns can further improve security effectiveness as organizational needs evolve.

Topics Explored:

- Data Collection and Aggregation
- Standardization and Normalization
- Enrichment and Analysis
- Sharing and Distribution
- Integration with Security Tools
- Customization and Flexibility
- Automation and Orchestration
- Community Involvement
- Incident Response Support
- Threat Intelligence Feeds
- Security Operations Center (SOC) and Security Information and Event Management (SIEM)

Tools Explored:

- Nmap
- Metasploit
- Nessus
- Kali Linux
- OWASP ZAP
- Burp Suite